

Meeting Cost Meter — SAST Evidence

Prepared for the Zoom App Marketplace security review of **Meeting Cost Meter** (Production), by Transformative Leadership Lab LLC.

Summary

The application undergoes **Static Application Security Testing (SAST)** on every change, using **GitHub CodeQL**. **Dynamic Application Security Testing (DAST) is not performed** — stated honestly here and in the SSDLC. This document is the evidence for the SAST half of the "SAST and/or DAST" review question.

Tool and configuration

- **Tool:** GitHub CodeQL (`github/codeql-action` v3).
- **Language pack:** `javascript-typescript`.
- **Query suite:** `security-extended` (the broader security query set).
- **Triggers:** every **push** and **pull request** to `main`, plus a **weekly scheduled scan** (Mondays 05:23 UTC).
- **Definition:** `.github/workflows/codeql.yml` (committed in the repository).
- **Where results appear:** the repository's **Security** → **Code scanning** tab.

Proof of execution — recent CodeQL runs

Date (UTC)	Trigger	Commit	Result
2026-07-27	schedule	<code>fe66af7</code>	success
2026-07-26	push	<code>fe66af7</code>	success
2026-07-26	pull_request	<code>c0ef5f8</code>	success
2026-07-26	push	<code>3ede488</code>	success
2026-07-25	pull_request	<code>b0a1e90</code>	success
2026-07-25	pull_request	<code>47122a3</code>	success

Findings and remediation — CodeQL analyses

Analysis (UTC)	Tool	Findings
2026-07-27 08:49	CodeQL	0
2026-07-26 23:22	CodeQL	0
2026-07-26 23:20	CodeQL	0
2026-07-26 00:30	CodeQL	4 (remediated)

- **Current open code-scanning alerts: 0.**
- The 4 findings from the 2026-07-26 analysis were triaged and remediated through the standard review-and-merge process (the `codeql-security-fixes` change); every subsequent scan reports 0. This demonstrates the SAST process operating end to end: detection → remediation → re-scan.

Independent verification

A reviewer with repository access can verify all of the above directly:

- **Workflow definition:** `.github/workflows/codeql.yml`
- **Run history and results:** GitHub → **Security** → **Code scanning** (and the Actions tab for CodeQL run logs) at `github.com/thomasbcox/zoom-meeting-cost`.

DAST

No Dynamic Application Security Testing is performed. This is consistent with the SSDLC policy (`ssdlc.pdf`), which documents SAST via CodeQL and states that DAST and third-party penetration testing are not currently conducted. The application's low-risk profile (session-only, no server-side data storage, a single `zoomapp:inmeeting` scope, no participant-data access) is the mitigating context for that scope.